

使用 Gemini CLI Security Extension 審查 GitHub 提取要求

來源：<https://codelabs.developers.google.com/gemini-cli/gemini-cli-security-review?hl=zh-tw>

步驟數：7

目錄

1. [1. 簡介](#)
2. [2. 事前準備](#)
3. [3. 設定從 GitHub 到 Google Cloud 的驗證](#)
4. [4. 建立 GitHub Actions 工作流程](#)
5. [5. 對新舊 PR 執行安全性分析工作流程](#)
6. [6. 進一步探索](#)
7. [7. 恭喜](#)

1. 簡介

[Gemini CLI Security Extension](#) 是 Google 建構的開放原始碼 Gemini CLI 擴充功能，可分析程式碼中的安全風險和漏洞。您可以使用 Gemini CLI 的 Security 擴充功能在本機找出安全性問題，就像使用任何其他 Gemini CLI 擴充功能一樣。您也可以叫用這項功能，在 GitHub 上審查提取要求。在本程式碼研究室中，我們將說明如何在 GitHub 存放區中使用 Security 擴充功能。

執行步驟

- 設定從 GitHub 到 Google Cloud 的安全驗證
- 建立 GitHub Actions 工作流程，呼叫 Gemini CLI Security Extension
- 使用 GitHub Actions 對新的或現有的提取要求執行安全性審查

課程內容

- 如何使用工作負載身分聯盟，從 GitHub Actions 安全地向 Google Cloud 進行驗證
- 瞭解使用 Workload Identity 集區和 Workload Identity 提供者進行驗證，相較於 Gemini API 金鑰的優點
- 如何使用 PR 執行安全性審查
- 如何解讀安全擴充功能回傳的安全審查結果

軟硬體需求

- 網路瀏覽器
- GitHub 帳戶和存放區
- 具備 Google Cloud 專案

本程式碼研究室的目標對象為熟悉 GitHub CI/CD 工作流程的開發人員。您不必熟悉 Gemini CLI 或 Gemini CLI 擴充功能。如要瞭解擴充功能的運作方式，請參閱程式碼實驗室：[開始使用 Gemini CLI 擴充功能](#)。

在本程式碼研究室中，您將瞭解如何在 GitHub 存放區中設定 Gemini CLI 安全性擴充功能。我們不會建議您針對存放區開啟 PR 的程式碼，以觸發安全漏洞發現。

2. 事前準備

從做中學 免付費

立即取得 Google Cloud 抵免額，並完成這個實驗室。無須提供信用卡或付款方式。

info

從做中學 免付費

立即取得 Google Cloud 抵免額，並完成這個實驗室。無須提供信用卡或付款方式。

啟用

建立或選取專案

1. 在 [Google Cloud 控制台](#) 的專案選取器頁面中，選取或建立 [Google Cloud 專案](#)。
2. 確認 Cloud 專案已啟用計費功能。瞭解如何[驗證帳單](#)。
3. 開啟 [Cloud Shell](#)，這是 Google Cloud 執行的指令列環境。點選 Google Cloud 控制台頂端的「啟用 Cloud Shell」。



4. 連至 Cloud Shell 後，請使用下列指令，確認您已通過驗證，且專案已設為您的專案 ID：

〇〇〇〇

```
gcloud auth list
```

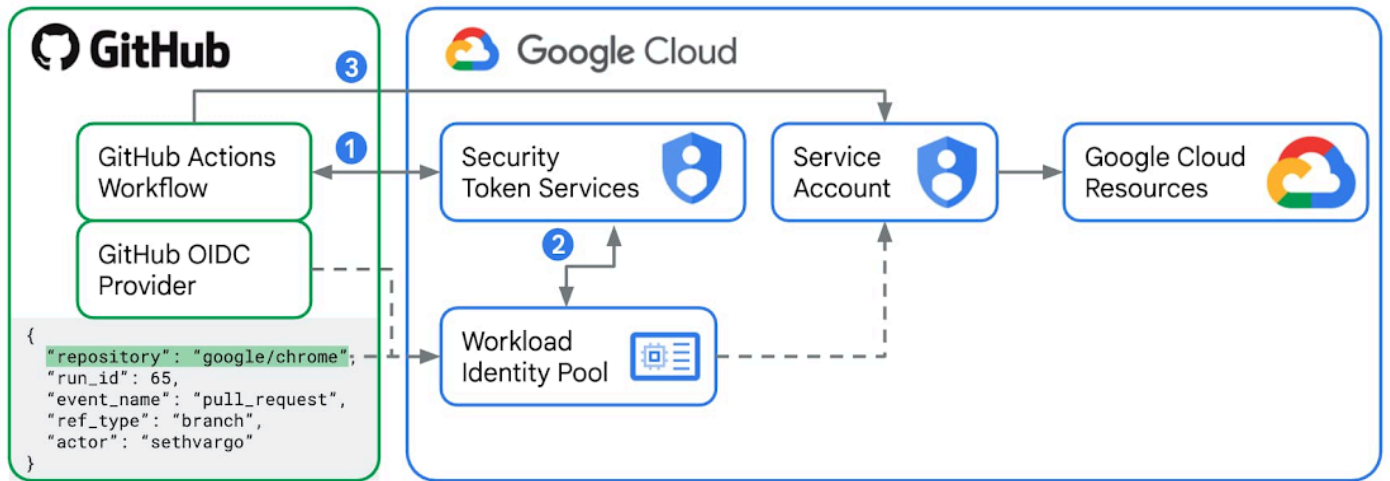
5. 執行下列指令，確認 `gcloud` 指令已設定為使用您的專案。

```
gcloud config list project
```

6. 如果未設定專案，請使用下列指令來設定：

```
gcloud config set project ${GOOGLE_CLOUD_PROJECT}
```

3. 設定從 GitHub 到 Google Cloud 的驗證運作方式



建議使用 [Workload Identity Federation](#)，從 [GitHub Actions](#) 向 Google Cloud 進行驗證。

- 對於每個 GitHub Actions [工作流程執行作業](#)，GitHub 會以外部身分識別提供者身分核發已簽署的 JWT (JSON Web Token)。這個權杖包含「權杖附加資訊」，例如 `repository`、`workflow` 和 `job_workflow_ref`，可做為特定執行元件的數位身分證。在本實驗室中，您將建立 GitHub Actions 工作流程，其中包含使用 `google-github-actions/run-gemini-cli` 動作的工作，該動作會向 GitHub 要求 JWT，並將這個權杖傳送至 Google Cloud 中的安全權杖服務 (STS)。
- 您將在 Google Cloud 中設定 **Workload Identity Pool** 和 **Provider**，方法是將簽發者網址設為官方 GitHub 權杖服務網址 `https://token.actions.githubusercontent.com`，並定義「屬性對應」，通常包括存放區和分支名稱。Google Cloud STS 會根據 Workload Identity Pool 規則驗證 JWT。如果一切正常 (包括屬性對應)，STS 會將 GitHub 權杖換成短期有效的 **Google Cloud 聯邦存取權杖**。
- 現在，GitHub Actions 工作流程中的 `google-github-actions/run-gemini-cli` 動作可以使用短期 **Google Cloud 聯合存取權杖**「模擬」已連結至 Workload Identity Pool 的服務帳戶。連結的服務帳戶必須具備必要的 IAM 角色和權限，才能存取任何 Google Cloud 資源和服務。

GitHub 使用 [直接身分聯盟](#)，不需服務帳戶模擬。不過，Gemini CLI 需要建立服務帳戶權杖，而這項作業僅支援透過服務帳戶 [模擬](#) 進行。

相較於 Gemini API 金鑰，使用 Workload Identity 聯盟的優點

您可以使用 Gemini API 金鑰，驗證源自 GitHub Actions 的 Gemini CLI 呼叫，方法是建立名為 `GEMINI_API_KEY` 的新 GitHub Actions Secret，並提供適當的金鑰值。不過，基於下列安全考量，我們不建議這麼做：

- Gemini API 金鑰可透過各自的 IAM 角色繫結，取得廣泛的權限。一旦遭到入侵，攻擊者就能存取各種 Google Cloud 資源和服務。Workload Identity Federation 會使用服務帳戶和短期存取權杖，大幅提升驗證安全性。
- 此外，大規模管理 Gemini API 金鑰也很困難。找出使用外洩金鑰的工作流程需要時間。手動輪替金鑰也需要時間。另一方面，您也可以透過 Cloud Console，輕鬆查閱、編輯及刪除與存放區相關聯的工作負載身分集區和供應商。
- 使用 Gemini API 金鑰時，請務必仔細檢查，確保不會在任何存取或偵錯記錄中意外公開金鑰。使用 Workload Identity Federation 時，您不會儲存任何 GitHub Actions 工作流程密鑰，而是儲存變數，這些變數本質上較不敏感。

設定 GitHub Actions 和 Google Cloud

1. 在 Cloud Shell 中登入 GitHub 帳戶。

```
gh auth login
```

2. 建立新檔案 `setup_workload_identity.sh`，然後從 [google-github-actions/run-gemini-cli](#) 存放區複製並貼上設定指令碼。
3. 將指令碼設為可執行檔。

```
chmod +x setup_workload_identity.sh
```

4. 執行指令碼。

```
./setup_workload_identity.sh --repo {OWNER/REPO} --project {GOOGLE_CLOUD_PROJECT}
```

步驟 4 · 約 5 分鐘

4. 建立 GitHub Actions 工作流程

1. 查看您擁有的 GitHub 存放區。

```
git clone {YOUR_REPO}
cd {YOUR_REPO}
```

2. 從 [/gemini-cli-extensions/security](#) 存放區複製範例工作流程 `yaml` 指令碼，建立呼叫斜線指令 `/security:analyze-github-pr` 的 GitHub Actions 工作流程。

```
git checkout -b workflow
mkdir .github/ && cd .github/
mkdir workflows/ && cd workflows/
curl -L https://raw.githubusercontent.com/gemini-cli-extensions/security/refs/heads/main/.github/workflows/gemini-review.yml -o gemini-review.yml
```

3. 將 GitHub Actions 工作流程推送至 GitHub 上的遠端來源。

```
git add .github/workflows/gemini-review.yml
git commit -m "add new gha workflow"
git push --set-upstream origin workflow
```

步驟 5 · 約 5 分鐘

5. 對新舊 PR 執行安全性分析工作流程

在 GitHub 存放區中啟動新的 PR，或以存放區擁有者或貢獻者身分發布新的註解「@gemini-cli /review」。這會啟動 PR 的安全性審查。您已提交至存放區的 GitHub Actions 工作流程中的 Gemini CLI 安全性擴充功能，會依嚴重程度類別 (從「重大」、「高」、「中」到「低」) 標記發現的任何安全性發現項目。

以下是新 PR 的[安全性審查範例](#)，以及現有 PR 的[安全性審查範例](#)。

步驟 6 · 約 5 分鐘

6. 進一步探索

我們建議您探索不斷擴充的自訂指令清單，瞭解 Gemini CLI 安全性擴充功能的新安全性功能，並開始在工作流程中使用。例如：

- `/security:scan-deps` 會將專案的依附元件與 [OSV.dev](https://osv.dev) 進行交叉參照。

如要瞭解最新功能和錯誤修正，請參閱[版本資訊](#)。

步驟 7 · 約 0 分鐘

7. 恭喜

恭喜！您已成功設定 GitHub 存放區，使用 Gemini CLI Security Extension 分析提取要求中的安全風險和漏洞。
